API Security Risk Analysis Report

Title: API Security Risk Analysis Report
Name: Preethi N
Internship Domain: Cyber Security
Program: Cyber Security Internship
Organization: Future Interns
Date:09th May 2026

1. Introduction

Application Programming Interfaces (APIs) play a critical role in modern applications by enabling communication between different software systems such as mobile apps, web platforms, and cloud services. APIs are widely used in Software-as-a-Service (SaaS) platforms and are essential for integrating services and exchanging data. However, insecure APIs can expose sensitive data and allow unauthorized access, making them a major target for cyberattacks. Therefore, analyzing API security is important to identify potential risks and ensure safe data handling. This report presents a security risk analysis of a public API by examining its behavior, identifying vulnerabilities, and suggesting appropriate mitigation strategies.

2. Objective

The objective of this task is to perform a security risk analysis of a public API by examining its structure, behavior, and response data. The analysis aims to identify common API security vulnerabilities such as lack of authentication, excessive data exposure, weak authorization, and missing security controls. Additionally, the objective is to evaluate the potential business impact of these risks and suggest appropriate remediation measures to improve API security. This task helps in understanding real-world API security practices and developing the mindset of a security analyst.

3. API Selected

API Name: JSONPlaceholder
Base URL: https://jsonplaceholder.typicode.com
Description:
JSONPlaceholder is a free online REST API used for testing and prototyping. It provides fake data such as users, posts, and comments, making it suitable for learning API testing and analysis.

4. Tools Used

- ❖ Postman (API testing and request analysis)
- ❖ Browser Developer Tools (inspection of responses and headers)
- ❖ Google Docs (for documentation)

5. Methodology

The following steps were followed to perform the API security analysis:

- ★ Selected a public test API (JSONPlaceholder)
- ★ Reviewed available endpoints
- ★ Sent HTTP requests using Postman
- ★ Observed API responses and headers
- ★ Checked for authentication and authorization mechanisms
- ★ Identified potential security risks
- ★ Classified risks based on severity
- ★ Suggested remediation techniques

6. Endpoints Tested

- ➢ GET /users
- ➢ GET /users/1

7. Identified Security Risks

Risk 1: No Authentication Mechanism
Severity: High
Description: The API allows access to endpoints without requiring any authentication such as API keys or tokens. This was verified by successfully accessing /users and /users/1 without any login or authorization.
Impact: Unauthorized users can access data freely, leading to potential misuse and data exposure.

Remediation: Implement authentication mechanisms such as API keys, OAuth tokens, or JWT-based authentication.

Risk 2: Excessive Data Exposure
Severity: Medium
Description: The API response includes detailed user information such as email, phone number, address, and geographic coordinates. This was observed in the API response from /users endpoint.
Impact: Exposure of sensitive data increases the risk of privacy violations and data misuse.

Remediation: Limit the data returned by the API to only necessary fields and avoid exposing sensitive information.

Risk 3: Broken Authorization
Severity: High
Description: Users can access data of other users by simply modifying the endpoint (e.g., /users/1, /users/2). This indicates lack of proper authorization checks.
Impact: This allows unauthorized access to other users' data, leading to data breaches.

Remediation: Implement proper authorization checks such as role-based or user-based access control.

Risk 4: No Rate Limiting
Severity: Medium
Description: The API does not restrict the number of requests sent in a short period. Multiple requests were sent using Postman without any restriction or blocking.
Impact: Attackers can abuse the API by sending excessive requests, potentially causing server overload or denial of service.

Remediation: Implement rate limiting to control the number of requests per user/IP.

Risk 5: Missing Security Headers
Severity: Low to Medium
Description: The API responses lack important security headers. This was observed in the Headers section of the response in Postman.
Impact:
This can expose the API to vulnerabilities such as cross-site scripting (XSS) and content sniffing.

Remediation:
Add security headers such as:

- ➢ Content-Security-Policy
- ➢ X-Content-Type-Options
- ➢ X-Frame-Options

8. Business Impact

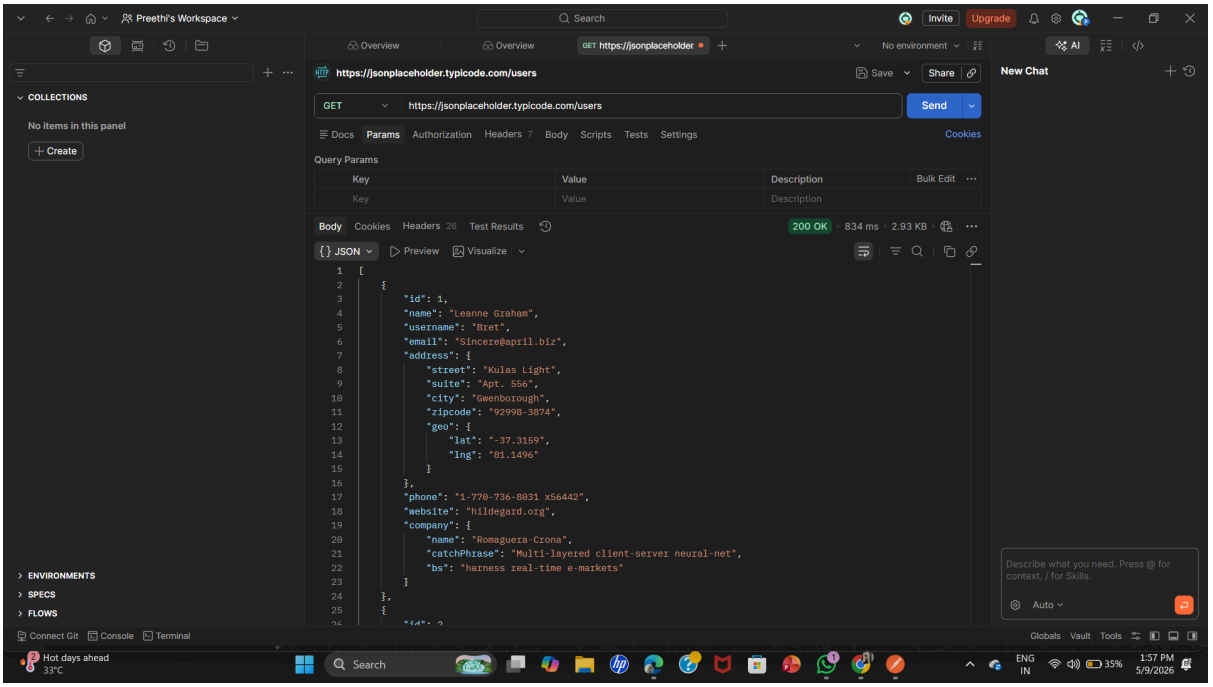
The identified vulnerabilities can have serious consequences:

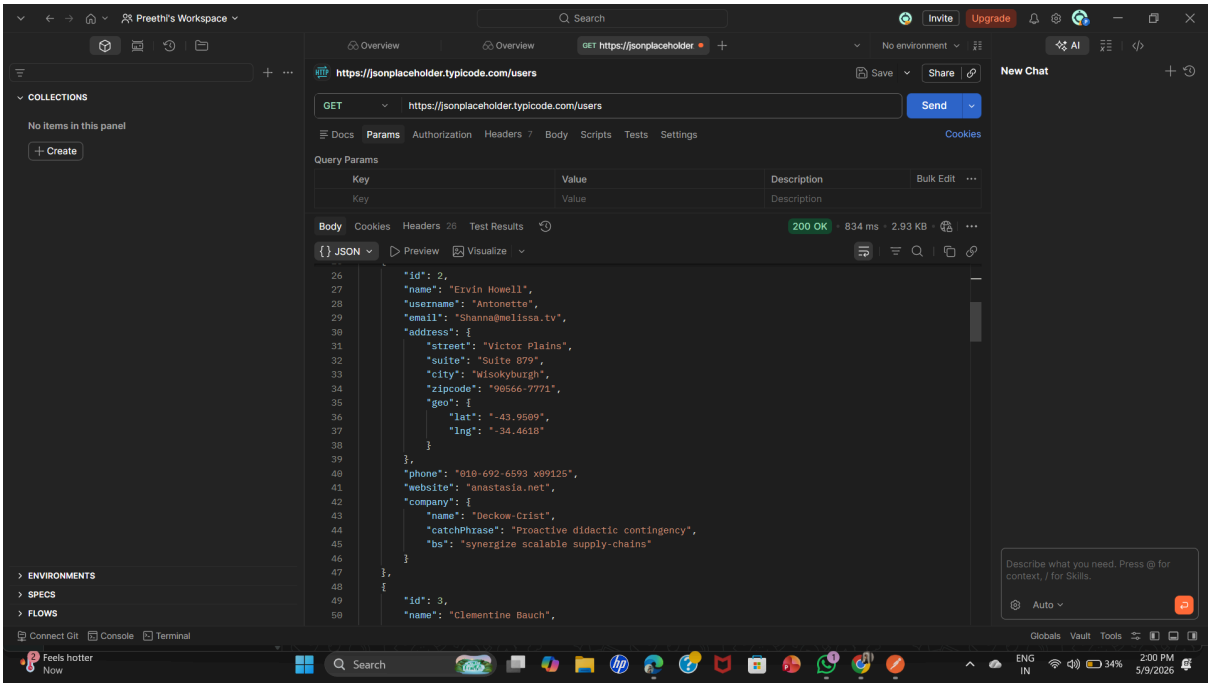
- ➔ Exposure of sensitive user data may lead to privacy violations
- ➔ Unauthorized access can result in data breaches
- ➔ Lack of rate limiting may cause service disruption
- ➔ Security weaknesses can damage organizational reputation
- ➔ Potential financial and legal consequences

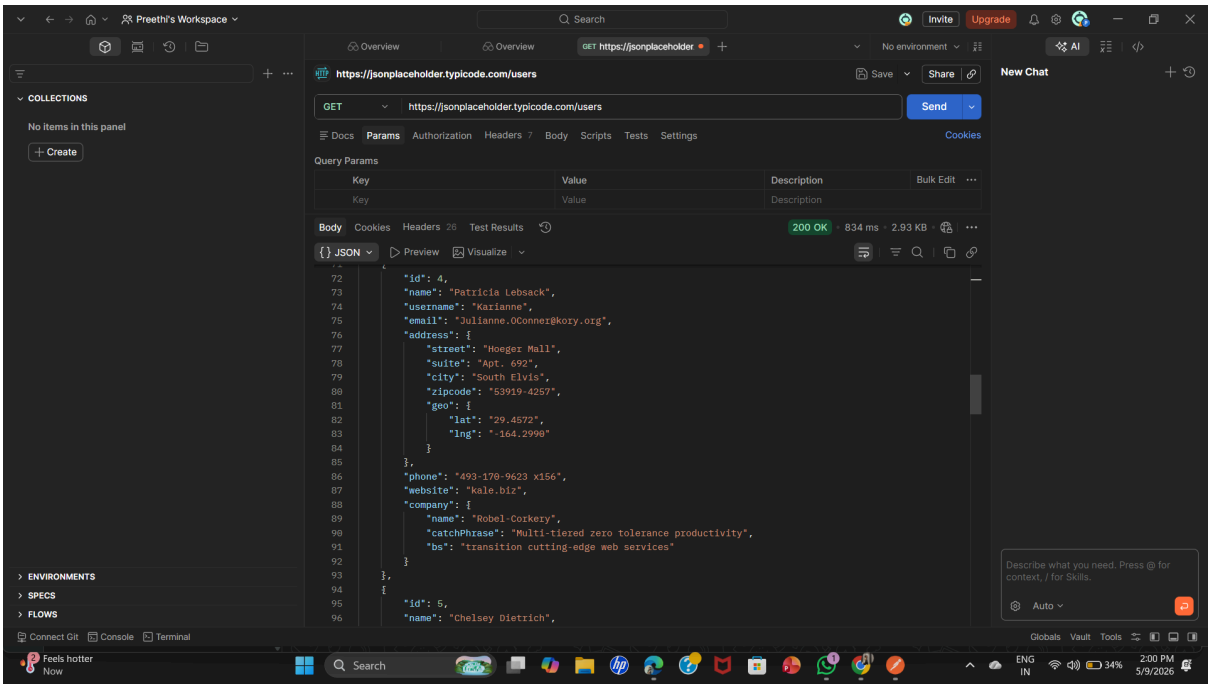
9. Screenshots

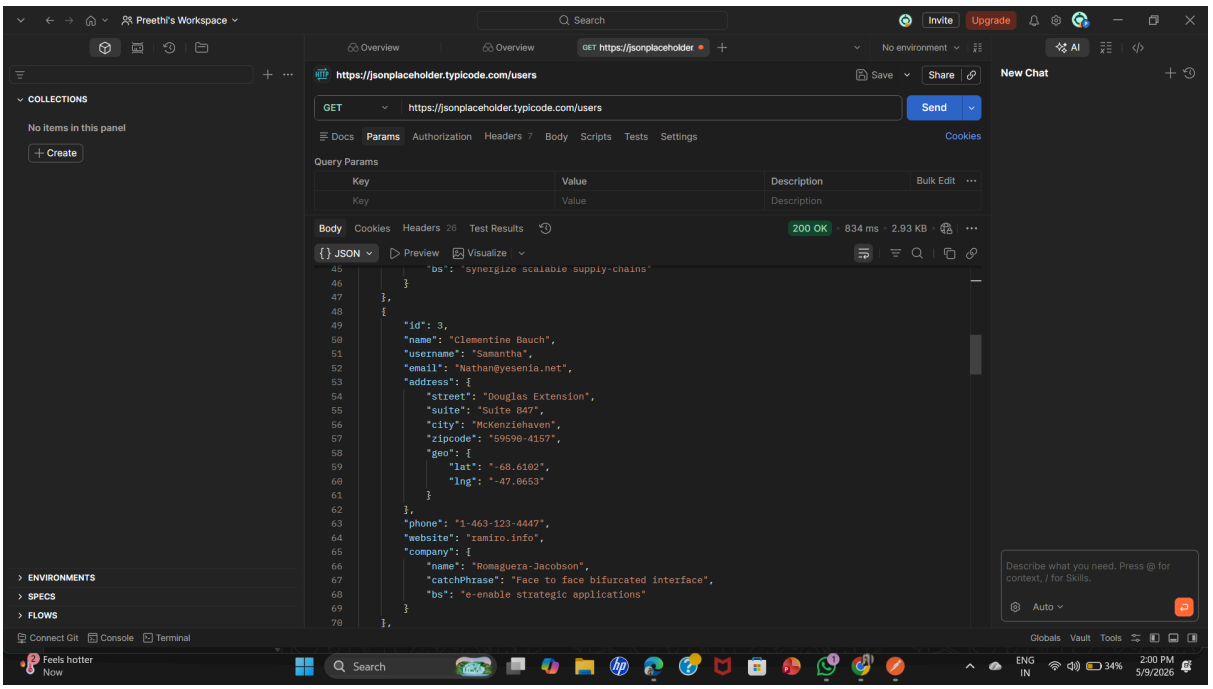
Screenshot 1: GET /users API Response

This screenshot shows multiple user records retrieved from the API. It demonstrates that the API exposes large amounts of user data without authentication



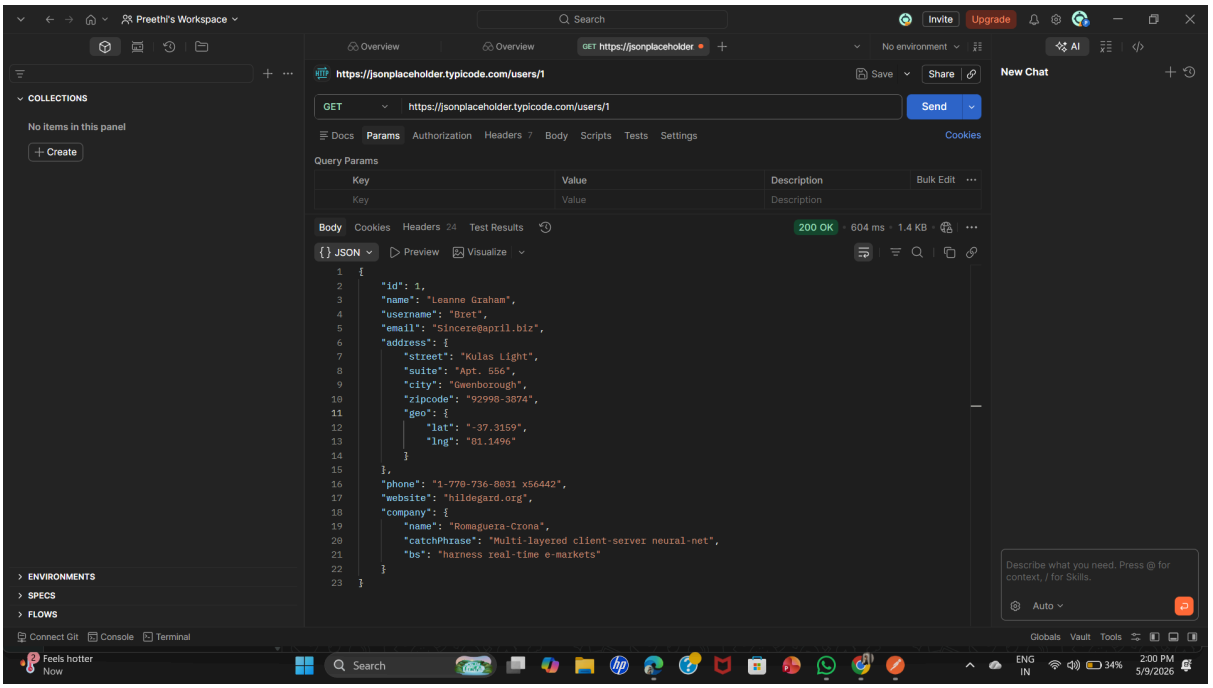






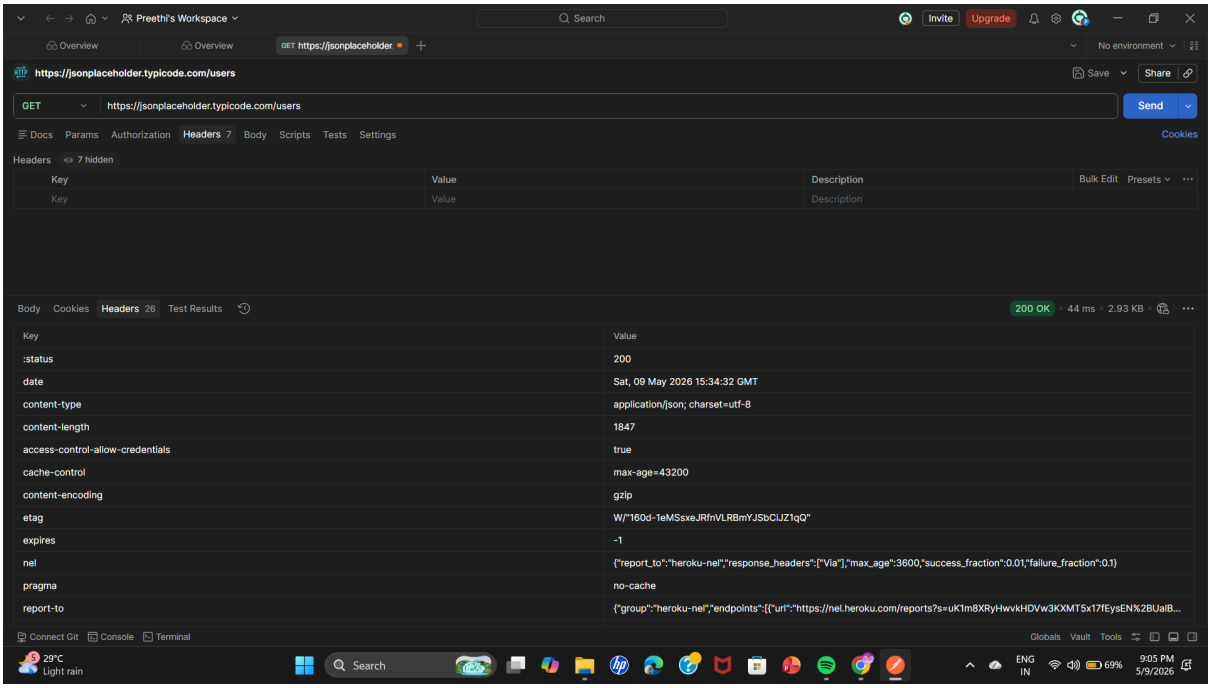
Screenshot 2: GET /users/1 API Response

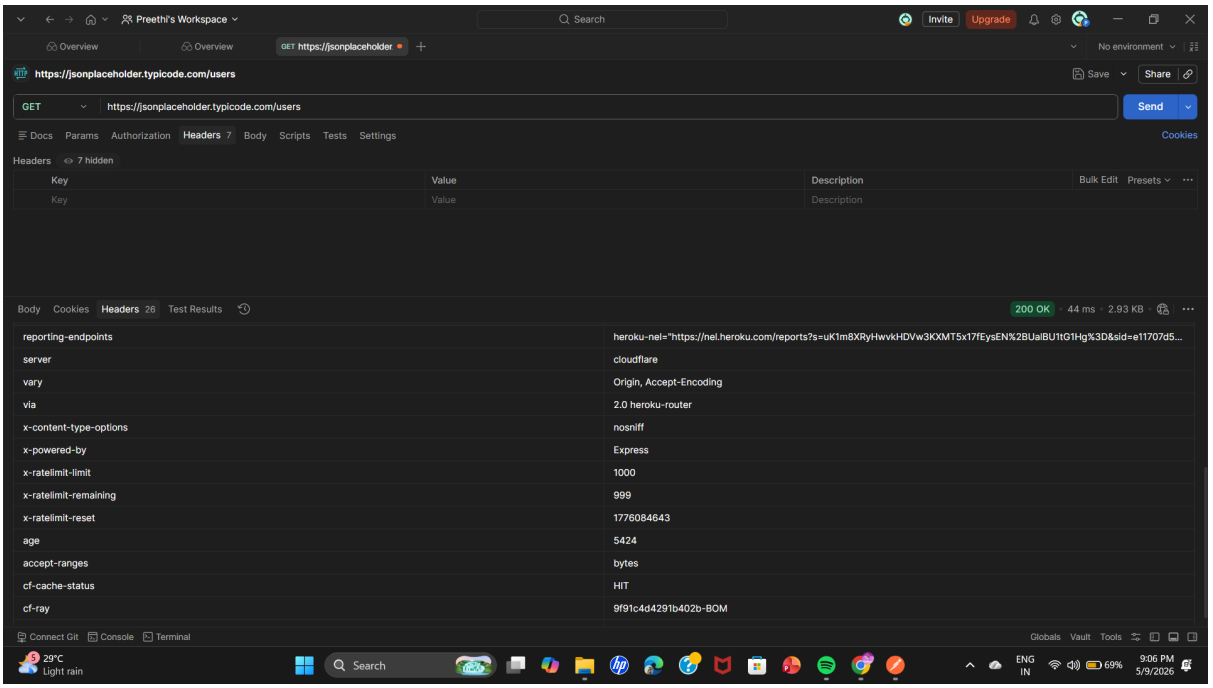
This screenshot shows detailed information of a specific user. It confirms that individual user data can be accessed directly without authorization.



Screenshot 3: Headers

This screenshot shows the response headers returned by the API. It indicates that important security headers are missing.





10. Conclusion

This analysis demonstrates that even publicly accessible APIs can have multiple security risks if proper safeguards are not implemented.
Issues such as lack of authentication, excessive data exposure, and missing security controls highlight the importance of secure API design.
Organizations must implement strong authentication, authorization, and data protection mechanisms to ensure API security and prevent potential attacks.